

Redes Botnets

Berli, Nahuel - Giampietro, Gustavo - Jaca, Juan Pablo - Mondino, Juan Cruz

Introducción



Las botnets no son siempre malas.

Malware $\neq$ botnet.

El malware es el software malicioso que puede infectar un dispositivo; la botnet es la red de dispositivos comprometidos que queda bajo control del atacante.

¿Qué es una Botnet?

DEFINICIÓN PRINCIPAL

"Red de computadoras conectadas que pueden ser controladas y utilizadas de forma coordinada para realizar determinadas acciones."

Arquitectura Básica: Bot-herder y Bots



Controlador

Bot-herder

Operador del conjunto de dispositivos mediante comandos remotos.



Zombis

Bots

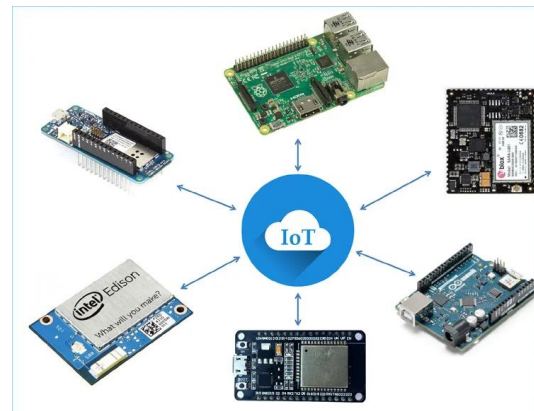
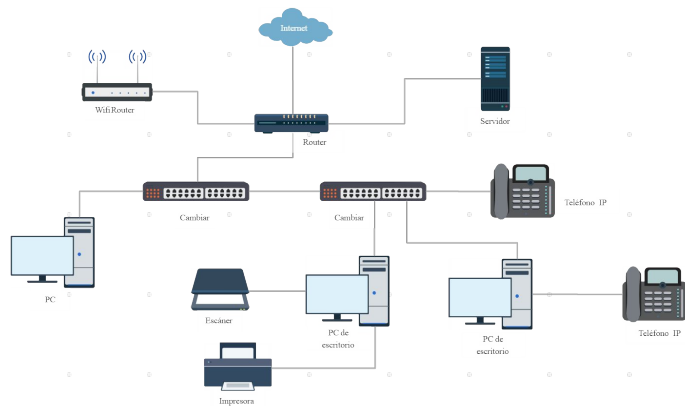
Dispositivos controlados.

Comportamiento

Los bots operan mecánicamente ejecutando la programación de comandos del controlador.

Superficie de Ataque

Todo dispositivo con una computadora interna:



Etapas de Creación de una Botnet

01 Preparación y exposición

Explotación de vulnerabilidades web o de red (ej. correos engañosos).

02 Infección

Descarga de malware mediante ingeniería social o descargas ocultas.

03 Activación

Organización remota de las máquinas infectadas para el ataque.

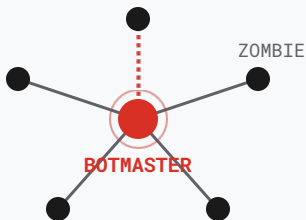
Modelos de Comando y Control (C&C)

Centralizado (Servidor-Cliente)

Estructura clásica basada en una **topología en estrella o jerárquica**. Todos los clientes zombie se reportan a un único punto centralizado.

▲ Alto riesgo de descubrimiento y neutralización del botmaster.

DIAGRAMA: TOPOLOGÍA EN ESTRELLA



Descentralizado (P2P)

Las instrucciones y comandos de control se distribuyen directamente **entre todas las computadoras zombis**, sin depender de intermediarios.

✓ Red robusta con un altísimo nivel de anonimato y resiliencia.

COMPLEJIDAD Y ROBUSTEZ TÉCNICA

Características del Modelo Distribuido

- **Propagación Cruzada:** Cada nodo actúa simultáneamente como cliente y servidor de comandos.
- **Estándar de Amenazas:** Es el modelo más implementado actualmente debido a la imposibilidad de apagar un único servidor.

Motivaciones

01

Beneficio Económico

Robo financiero, extorsión, minería de criptomonedas.

02

Operaciones

Sabotaje de servicios, robo de información confidencial.

03

Mercado Negro

Venta o alquiler de la red a otros delincuentes (ej. campañas de spam).

04

Prestigio

Demostración de habilidades de piratería.

Tipos de Ataques



DDOS

DDoS

Sobrecarga masiva de servidores con tráfico web para bloquearlos.



PHISHING

Phishing

Campañas de spam para robar credenciales bancarias o correos.



FUERZA BRUTA

Fuerza Bruta

Relleno de credenciales y ataques de diccionario contra contraseñas débiles.

Tipos de Ataques



AMENAZA: BOT

Zombies

Control total del equipo mediante caballos de Troya.



AMENAZA: SPYWARE

Spyware

Fraude automatizado de clics en publicidad para generar ingresos.



AMENAZA: ACCESO

Acceso Telefónico

Marcación forzada a números premium desde módems (en desuso).

Casos Conocidos de Botnets

■ 911 S5:

Considerada una de las redes más grandes de la historia, convertía las PCs infectadas en proxies.

■ Zeus:

Interceptaba el tecleo del usuario para robar datos bancarios.

■ Methbot:

Red de bots que convertía ordenadores en visores de anuncios, generando así ingresos para su creador.

■ Emotet:

Infectaba a través de phishing o archivos Word. Se originó como malware de robo de credenciales bancarias.

■ EarthLink Spammer:

Fue uno de los primeros ataques de botnet. Llegó a representar un 25% del spam mundial.

■ Phorpiex:

Enviaba spam masivo, luego incorporó crypto-clipping. Se desactivaron los servidores en 2021.

Estrategias de Deshabilitación



ESTRATEGIA CENTRALIZADA

Nivel de Control

Identificar y desactivar los servidores C&C (cortar la "cabeza").



ESTRATEGIA LOCAL

Nivel de Dispositivo

Reinstalar el sistema operativo, formatear o restablecer de fábrica (IoT) para eliminar la infección individual.

Estrategias de Mitigación



FILTRADO DE ENTRADA

Filtrado de Entrada

Examina y bloquea paquetes de datos maliciosos que intentan ingresar a la red.



FILTRADO DE SALIDA

Filtrado de Salida

Detiene el flujo de datos maliciosos hacia el exterior, evitando la propagación entre computadoras.



EJECUCIÓN DE TERCEROS RESTRINGIDA

Políticas de kernel activas para el aislamiento estricto de código no firmado.

Consejos de Prevención para Usuarios



Credenciales

Usar contraseñas largas y complejas; cambiar claves predeterminadas de fábrica.



Hardware

Evitar dispositivos IoT de seguridad deficiente.



Navegación

No descargar adjuntos sospechosos ni hacer clic directo en enlaces.



Protección

Instalar software antivirus efectivo.